

CTF 문제 출제 의도 보고서

문제명: EasyHajo

1. 문제 개요 (Challenge Overview)

- 난이도:** 쉬움(Easy) / 보통(Medium)
- 분야:** 웹 해킹(Web Hacking), 권한 상승(Privilege Escalation)
- 문제 설명:** 웹 애플리케이션의 설정 오류와 파일 시스템의 보안 미비를 통해, 초기 침투부터 루트(Root) 권한 획득까지의 전 과정을 경험하는 다단계 시나리오입니다.

2. 학습 목표 (Learning Objectives)

- 웹 취약점 탐지:** 서버 설정 오류(백업 파일 노출)로 인한 정보 유출 식별 능력을 배양합니다.
- 인증 로직 우회:** 자동화 도구(Burp Suite)를 활용한 논리적 검증 우회 기법을 이해합니다.
- 명령어 삽입:** 입력값 검증 미흡을 이용한 OS 명령어 실행 취약점을 학습합니다.
- 권한 상승:** 관리자 권한으로 실행되는 스크립트의 취약점을 이용한 최종 제어권 획득 과정을 분석합니다.

3. 공격 시나리오 (Exploitation Path)

단계	목표	핵심 기법
Step 1	초기 정찰	포트 스캔 및 디렉토리 브루트 포싱
Step 2	소스 코드 분석	백업 파일(*.bak) 분석을 통한 인증 로직 우회
Step 3	초기 침투	파일 업로드 취약점 및 리버스 셸 연결
Step 4	내부 정찰	명령어 삽입을 통한 시스템 내부 정보 수집
Step 5	권한 상승	sudo 권한 오용을 통한 루트 셸 획득

4. 세부 출제 의도 (Detailed Design Intent)

- **백업 파일 노출:** "보안의 시작은 설정에서부터"라는 점을 강조하기 위해 개발자가 흔히 저지르는 실수(백업 파일 방치)를 의도적으로 배치했습니다.
- **쿠키 검증 우회:** 단순 고정값 대입이 아닌, 작은 규칙성(알파벳 1자리)을 찾아내어 공격을 자동화하는 능력을 평가하고자 했습니다.
- **명령어 삽입 활용:** `helper.php` 를 통해 시스템의 내부 구조를 파악하게 함으로써, 단순히 웹 서버 내부에 머무는 것이 아니라 호스트 전체를 정찰하는 과정을 설계했습니다.
- **sudo 권한 오용:** 시스템 관리자가 부여한 `NOPASSWD` 권한이 얼마나 치명적인 결과를 초래할 수 있는지, 입력값 검증이 없는 스크립트의 위험성을 보여주고자 했습니다.

5. 성취 단계 및 플래그 (Milestone & Flag)

1. **User Flag:** 시스템 침투 후 `/home/easyhajo/user.txt` 를 통해 일반 사용자 수준의 권한 확보를 인증합니다.
2. **Root Flag:** `cookie-gen.py` 의 취약점을 이용해 `/root/root.txt` 를 획득함으로써 최종 관리자 권한을 인증합니다.

6. 참가자 힌트 (Hints for Participants)

- **Hint 1:** 웹 서버의 디렉토리에 접근할 수 있는 모든 파일을 확인해보세요. 숨겨진 확장자가 있을지 모릅니다.
- **Hint 2:** `upload.php` 는 정말로 쿠키 값만으로 검증할까요? Burp Suite로 패킷의 변화를 관찰하세요.
- **Hint 3:** 서버에서 실행할 수 있는 명령어 중, `sudo` 권한으로 실행되는 파일은 무엇인가요? `sudo -l` 을 사용해 보세요.